



Sri Lanka Institute of Information Technology

APPLIED INFORMATION ASSURANCE – ASSIGNMENT 02

PENETRATION TESTING REPORT FOR MAYO INDUSTRIES

Submitted by:

Registration Number	Name
IT23659230	LAKSHAN W.M.H.C

Date of Submission:

07.04.2026

Contents

Executive Summary	3
2. Scope of Assessment.....	4
3. Assumptions.....	5
4. Introduction	6
5. Team Structure and Roles.....	6
6. Red Team – Offensive Assessment	7
7. Blue Team – Defensive Analysis	13
8. Purple Team – Collaboration and Effectiveness.....	15
9. Technical Findings	16
10. Business Impact Assessment	17
11. Remediation Roadmap	18
12. Conclusion.....	19

Executive Summary

The penetration testing assessment was carried out in a controlled laboratory setting aimed at analyzing the security posture of Mayo Industries from the offensive, defensive, and collaborative points of view. The assessment process was carried out by creating an artificial environment where one computer running on the Kali Linux operating system was used as the attacking computer, while another computer running on the Kali Linux operating system was hosting the Damn Vulnerable Web Application (DVWA).

The assessment was done using a team approach using three different teams, which were the Red Team, Blue Team, and Purple Team. The Red Team evaluated any possible vulnerabilities from reconnaissance, enumeration of services, and application-based penetration testing. The Blue Team evaluated the efficiency with which the environment could detect, mitigate, and counter any simulated attacks by the Red Team. The Purple Team would then compare the results of the attacks by the red team with the preparedness of the environment.

In this case, quite a number of weakness was discovered during the assessment process. This involved network based discovery and enumeration that showed that the targeted system was accessible and presented a number of services available for exploitation by the attacking system. Weakness discovered included availability of the exposed service, poor implementation of authentication related functionality, SQL injection, and reflected cross site scripting vulnerability. In addition, the presence of an attack surface is evident since there exists poor behavior on the application level.

From a business point of view, the potential threats identified above may cause problems like unauthorized access, data exposure, breach of confidentiality, lack of trust on the application, and disruption in operations. If there was a live implementation of such an issue, it would have also resulted in reputation loss, costs involved in handling incidents, and a loss of customer trust.

In summary, the findings from the risk assessment indicate that there is a need for improved security within the targeted environment in terms of exposure, authentication, applications, and monitoring. The recommendations provided in this report can help ensure improved security in Mayo Industries and decrease the chance of future exploitation.

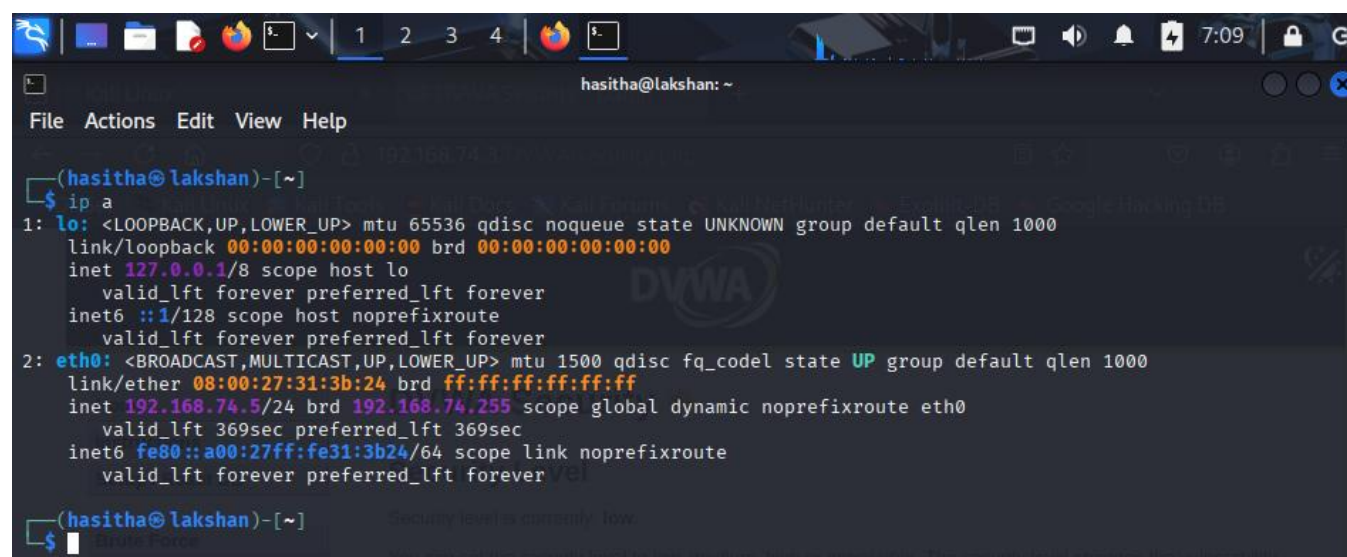
2. Scope of Assessment

Type	Name	Scope
Attacker Machine	Kali Linux	Reconnaissance and manual testing
Victim Machine	Kali Linux	Host machine for target application
Web Application	DVWA	Login page, user input fields, authentication modules

However, the assessment process was limited to a lab activity that was carried out in an environment simulated at Mayo Industries. For example, the attack was configured in such a manner that a Kali Linux virtual machine was used to do the reconnaissance, service enumeration, and manual interaction with the target application. Similarly, the victim environment was configured by setting up a Kali Linux virtual machine running the Damn Vulnerable Web Application (DVWA). The entire assessment included testing the availability of the network connection to the target host, service enumeration, web application interaction, and vulnerability assessment of application components.

The target environment was that of the victim host, which had an IP address of 192.168.74.3 and was accessed via the attacker host with an IP address of 192.168.74.5. The scope covered the confirmation of network connectivity, identification of active hosts, listing services, accessing the web application under the target, and vulnerability assessment on specific modules in DVWA. The scope did not go beyond the virtual academic lab environment.

Figure 1. Attacker machine IP configuration.



```
(hasitha@lakshan)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:31:3b:24 brd ff:ff:ff:ff:ff:ff
    inet 192.168.74.5/24 brd 192.168.74.255 scope global dynamic noprefixroute eth0
        valid_lft 369sec preferred_lft 369sec
    inet6 fe80::a00:27ff:fe31:3b24/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
(hasitha@lakshan)-[~]
```

Figure 2. Victim machine IP configuration.

```
(hasitha@hasitha)-[/var/www/html/DVWA]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:45:2b:a9 brd ff:ff:ff:ff:ff:ff
    inet 192.168.74.3/24 brd 192.168.74.255 scope global dynamic noprefixroute eth0
        valid_lft 527sec preferred_lft 527sec
    inet6 fe80::a00:27ff:fe45:2ba9/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

Figure 3. Successful ICMP connectivity between the attacker and victim machines.

```
(hasitha@lakshan)-[~]
$ ping 192.168.74.3
PING 192.168.74.3 (192.168.74.3) 56(84) bytes of data.
64 bytes from 192.168.74.3: icmp_seq=1 ttl=64 time=1.20 ms
64 bytes from 192.168.74.3: icmp_seq=2 ttl=64 time=0.486 ms
64 bytes from 192.168.74.3: icmp_seq=3 ttl=64 time=1.18 ms
64 bytes from 192.168.74.3: icmp_seq=4 ttl=64 time=0.989 ms
^C
— 192.168.74.3 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3130ms
rtt min/avg/max/mdev = 0.486/0.963/1.202/0.287 ms
```

3. Assumptions

The following assumptions were made during the assessment:

1. The penetration testing activity was conducted entirely within a legal and isolated academic lab environment.
2. The attacker machine was intentionally configured to simulate hostile activity for assessment purposes.
3. The victim machine hosted DVWA and supporting services such as Apache and MariaDB.
4. The findings were validated only to the extent necessary to demonstrate vulnerability exposure and business relevance, without causing destructive or permanent impact.
5. All screenshots, command outputs, and visible evidence included in the report were collected directly during the lab exercise.
6. The target environment was assumed to represent a simplified model of an enterprise web application deployment for the purpose of demonstrating penetration testing methodology and analysis.

4. Introduction

A penetration test is a structured security assessment technique designed to uncover, assess, and document vulnerabilities in networked infrastructure and software systems. It is used by companies to determine how vulnerable they are to attacks using such techniques and whether their protective measures are sufficient. The penetration testing technique was conducted under laboratory conditions in this particular case study to assess the security of the Mayo Industries web platform.

Besides pointing out vulnerabilities, this report aims to analyze the importance of these vulnerabilities, both from technical and business points of view. It will also be examined if the environment is able to detect and react against the activities described as well as if the mitigation measures provided will lower the identified risks. Instead of providing technical analysis only, by taking into consideration the views of all three types of teams – Red, Blue, and Purple – an insight on the state of security within the environment will be given.

This will be done by conducting practical penetration tests of the techniques learnt in the laboratory sessions in the module. This includes assessing network level, reconnaissance, service enumeration, application level access, manual penetration tests for the vulnerability assessment of the modules, analysis of the defense level, and recommendations for improvement. Thus, this report outlines a systematic approach to analyzing the vulnerability of the virtual Mayo Industries network environment.

5. Team Structure and Roles

The assessment was conducted by adopting three different, yet complementing security frameworks – Red Team, Blue Team, and Purple Team.

The first framework, the Red Team, represented the attackers' perspective. It entailed host discovery, reconnaissance on the network, service enumeration, validation of access and, finally, manual testing of the DVWA web application. The objective of the Red Team was to find security weaknesses that may be leveraged by adversaries to compromise hosts or applications and retrieve information from there.

The second security framework, Blue Team, involved the analysis of the effectiveness of the current control measures used by the company to defend against attacks. Specifically, it included an evaluation of how effectively the environment can resist or respond to actions taken by Red Team. The Blue Team framework is important for assessing not just vulnerabilities but how ready the current defense mechanisms were to resist attack.

Finally, the Purple Team bridged both Red and Blue Teams' assessments to help identify security gaps and determine if the proposed countermeasures were adequate enough. The latter will assist in addressing the requirements of this assignment to evaluate the effectiveness of current security controls and provide recommendations to improve it.

6. Red Team – Offensive Assessment

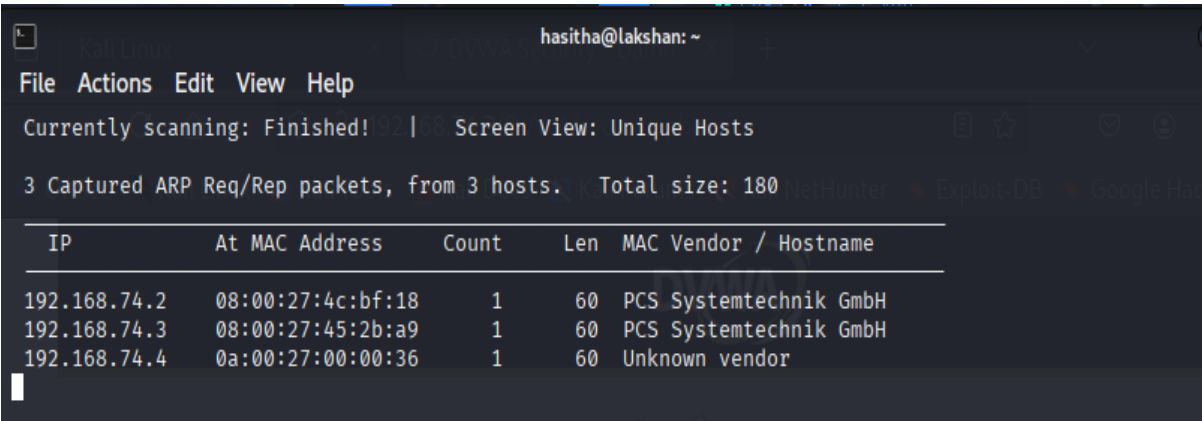
6.1 External Network Assessment

The external network assessment started with the identification of both the attacker and the victim systems within the local subnet. First of all, the attacking system checked if the target host is available using ICMP requests that verified the availability of the targeted system and its network connectivity. That step was necessary since the presence of the target system had to be verified in advance.

After that, the network discovery was done to discover other systems present in the local network. It helped to confirm the existence of the victim host and set its IP address within the environment. Next, the service enumeration was performed on the attacking machine that identified what kind of open ports and services were present on the victim host. As the result of the scan, the target host appeared to expose SSH service on port 22 and HTTP service on port 80. Thus, the target host has been revealed to be accessible from outside and the attacker can continue its actions with this knowledge.

The presence of open SSH service allows to assume that there might be some unauthorized attacks aimed at gaining access to this service in case it is misconfigured or uses weak credentials. At the same time, the exposed HTTP service provides a possibility to gain access directly to the web application layer making it a major source of attack for application-level security testing that would be done next.

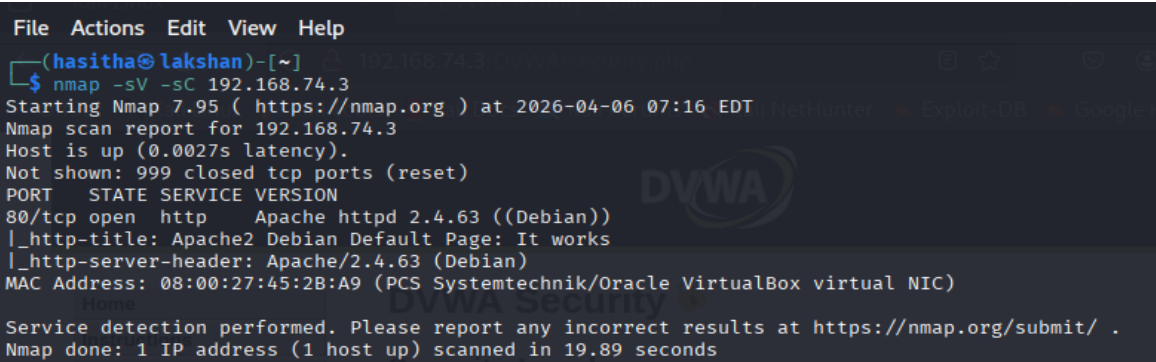
Figure 4. Host discovery within the local subnet.



The screenshot shows the Nmap interface with the ARP table. The title bar indicates the user is 'hasitha@lakshan'. The menu bar includes File, Actions, Edit, View, and Help. The status bar shows 'Currently scanning: Finished!' and 'Screen View: Unique Hosts'. Below this, it states '3 Captured ARP Req/Rep packets, from 3 hosts. Total size: 180'. The main table has columns: IP, At MAC Address, Count, Len, and MAC Vendor / Hostname. The data rows are as follows:

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.74.2	08:00:27:4c:bf:18	1	60	PCS Systemtechnik GmbH
192.168.74.3	08:00:27:45:2b:a9	1	60	PCS Systemtechnik GmbH
192.168.74.4	0a:00:27:00:00:36	1	60	Unknown vendor

Figure 5. Nmap service enumeration results showing exposed services on the target host.



```
File Actions Edit View Help
(hasitha@lakshan)-[~]
$ nmap -sV -sC 192.168.74.3
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-06 07:16 EDT
Nmap scan report for 192.168.74.3
Host is up (0.0027s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.63 ((Debian))
|_ http-title: Apache2 Debian Default Page: It works
|_ http-server-header: Apache/2.4.63 (Debian)
MAC Address: 08:00:27:45:2B:A9 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.89 seconds
```

6.2 Internal Network Assessment

During the process of internal network assessment, attention was paid to a potential attacker that had already gained access to the local network. In this case, the attacker might have a greater advantage in enumerating systems, communicating with internal network services, and gaining additional access to vulnerable applications and administrative services. No malicious actions such as lateral movement or privilege escalation were performed by the intruder in the lab. However, there were still aspects worth mentioning concerning the internal security assessment.

Considering the fact that the system under investigation offered HTTP and SSH service access, a potential attacker could communicate with these services easier. As a consequence, any weaknesses related to authentication, configuration, hosts, and network segmentation could result in the overall network penetration. In the case of a corporate infrastructure being compromised through the weaknesses mentioned above, the hacker would continue penetrating the environment in order to find other valuable resources.

Therefore, internal security measures should take into account not only the prevention of outside threats but also limitations on the actions of users and systems.

6.3 Web/Application Assessment

The assessment of the application consisted of analysis of the DVWA platform that was located on the victim machine. After confirming the accessibility of the web service, the attacker went to the DVWA login page and logged into the application. Then, after logging into the application, the attacker assessed the current configuration of the application security settings and tested certain modules to detect the vulnerabilities.

The list of identified weaknesses includes several vulnerabilities that are worth mentioning. First of all, the behavior of the application regarding the process of login demonstrated a lack of effective controls of consecutive attempts to log in and use the application credentials, making possible an attack based on brute force. Secondly, behavior concerning user inputs demonstrated that the application is prone to SQL injections, which means that there are no proper procedures to process user input in order to avoid any issues while using the database. Thirdly, reflected input behavior demonstrated the presence of reflected cross-site scripting (XSS).

It should be mentioned that this list demonstrates several serious problems related to application-level security issues since they make it possible to exploit sensitive functionality of applications directly, without compromising system-level aspects. Specifically, SQL injection can be used to change queries and steal information from a database. Reflected XSS allows for executing malicious scripts in a victim user's browser. Moreover, weak authentication control can cause many attacks aimed at accessing the victim accounts. Thus, application layer is one of the most important security levels to protect.

Figure 6. DVWA login page accessible from the attacker machine.

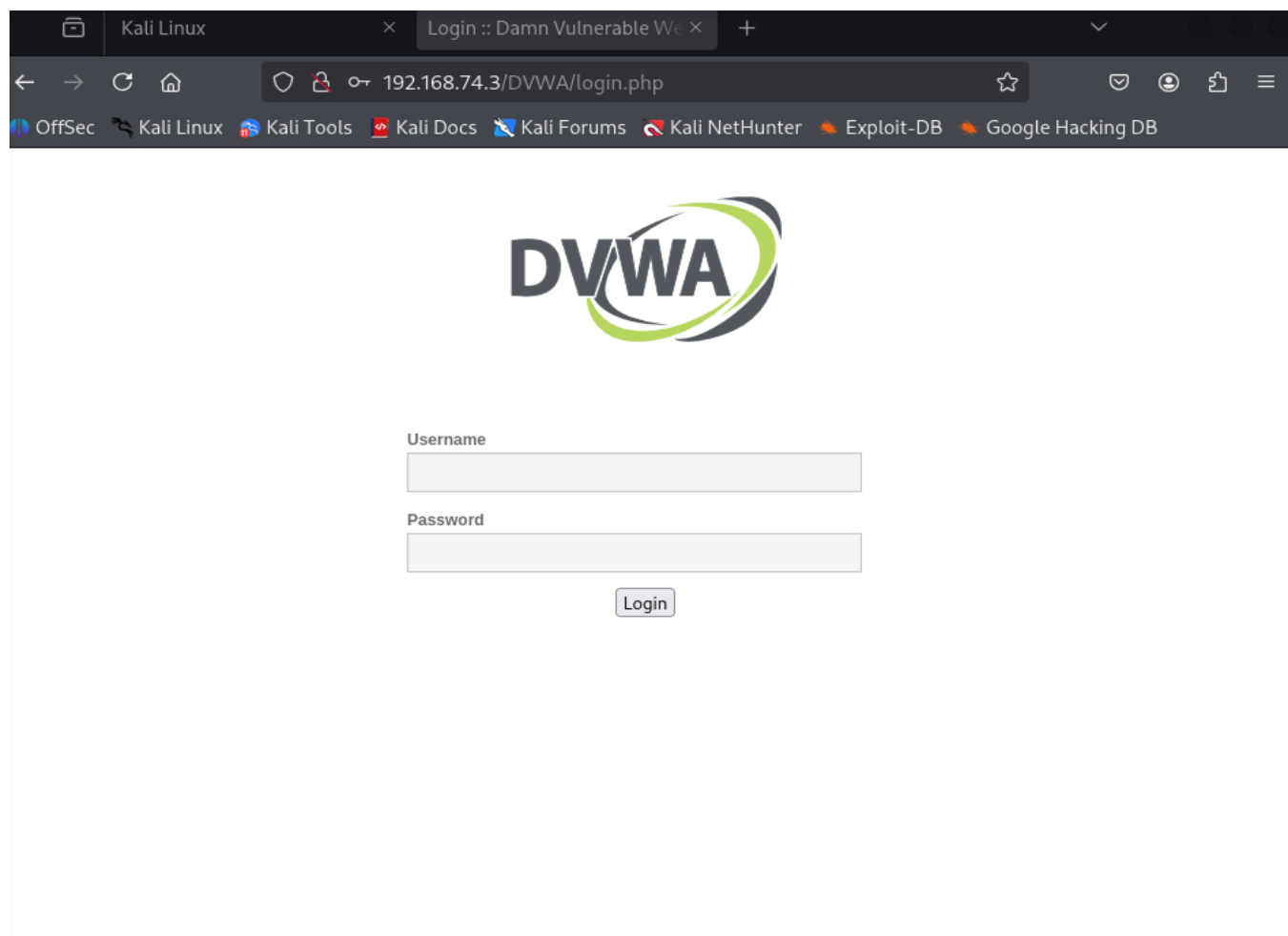


Figure 7. DVWA dashboard following successful authentication.

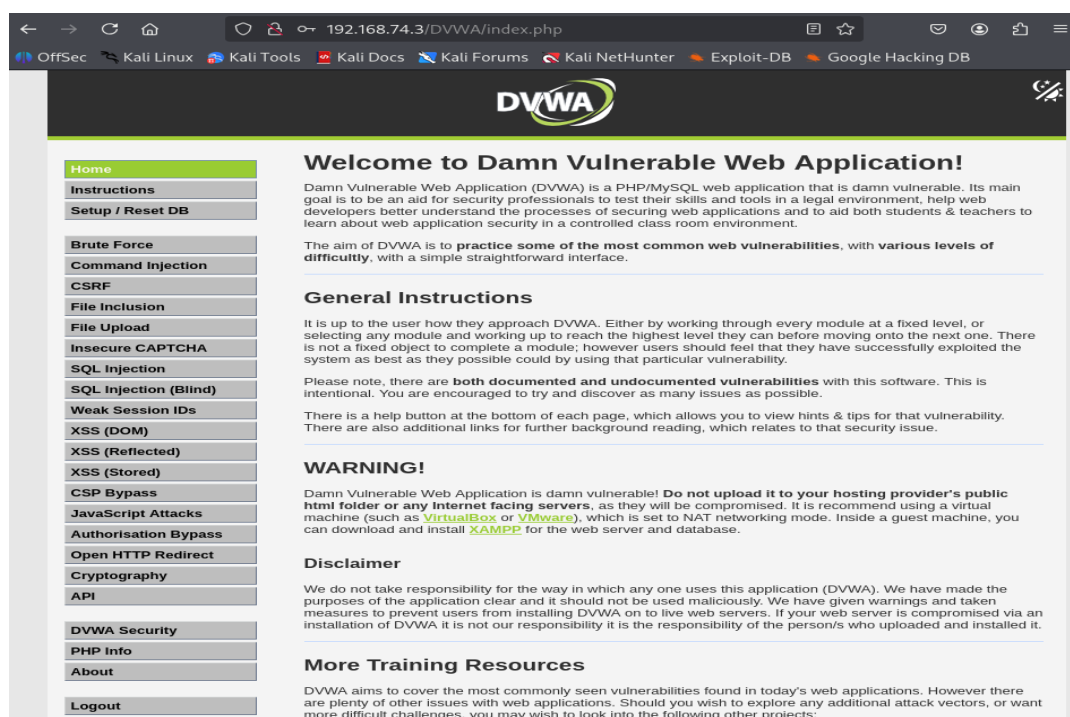


Figure 8. Application security configuration used during testing.

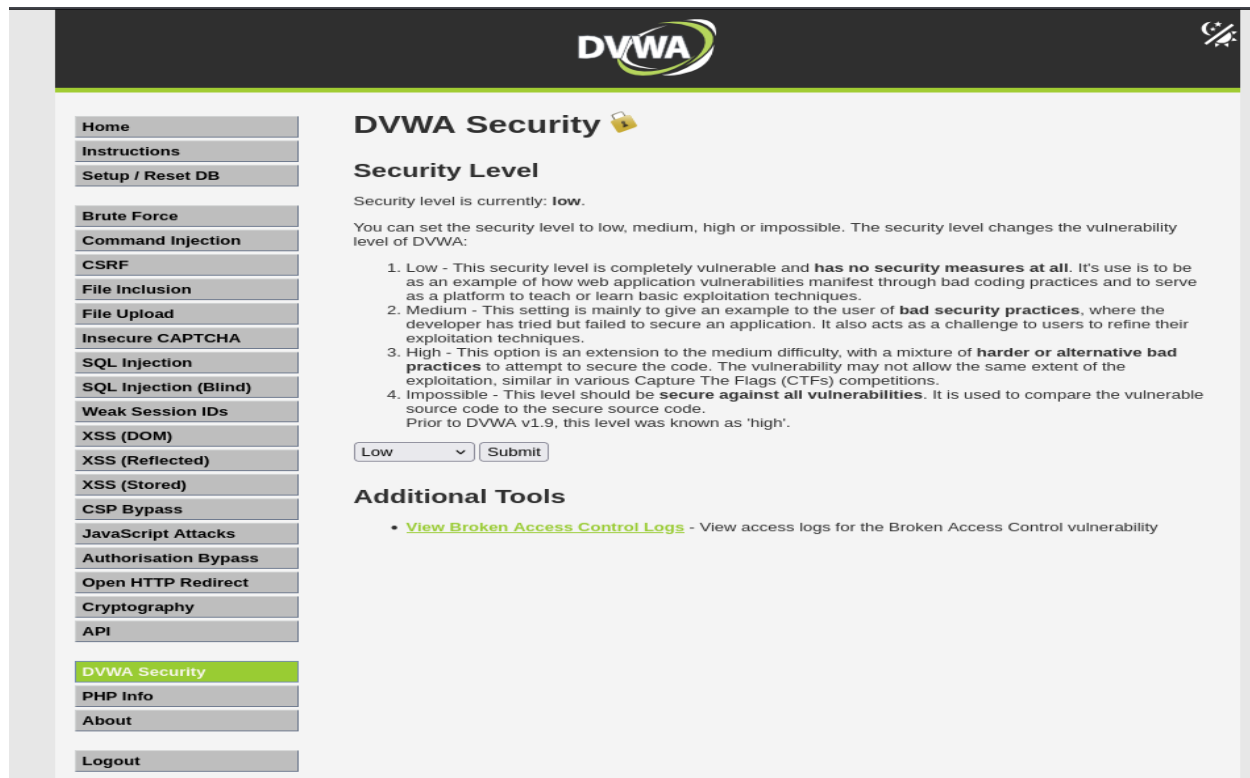


Figure 8.1. Brute Force page before login attempt

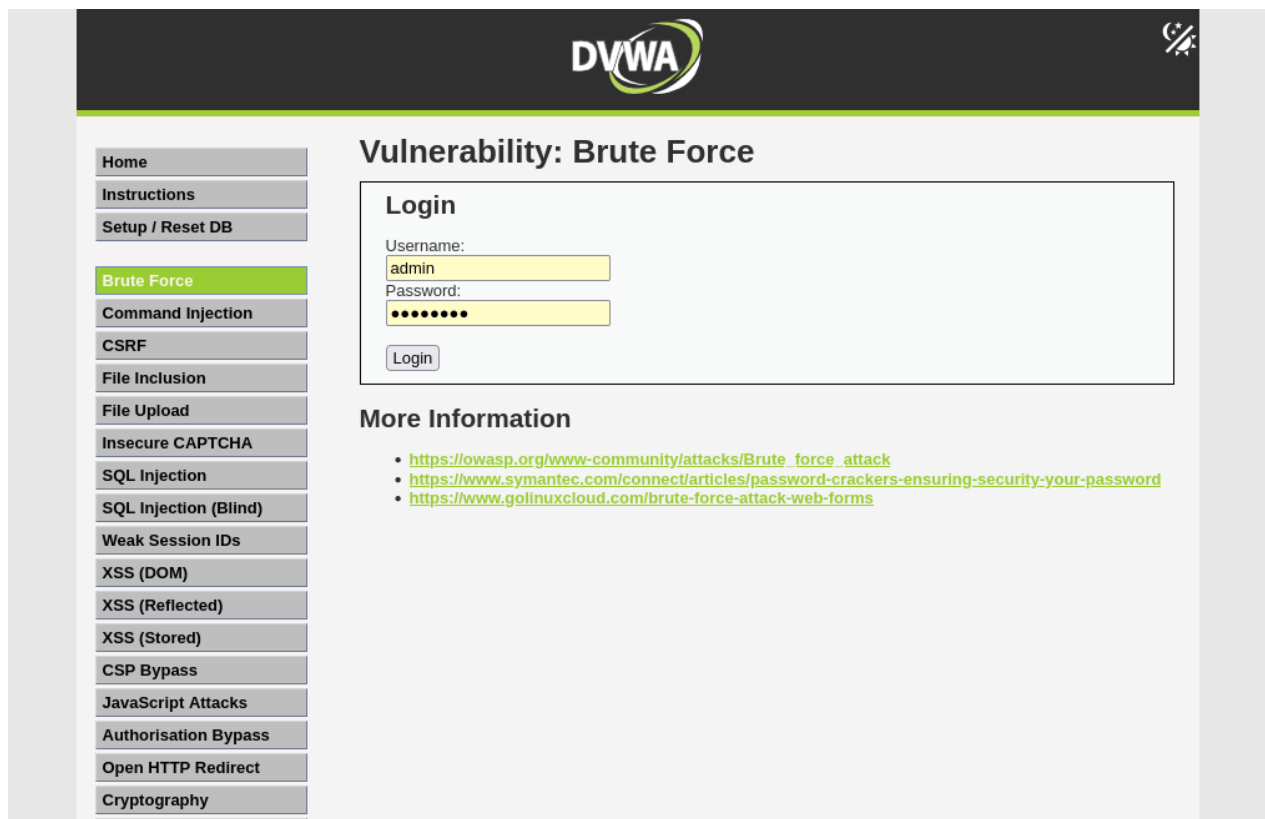


Figure 8.2. after 2–3 failed attempts, still no lockout/protection



Figure 9. SQL Injection test interface within DVWA.

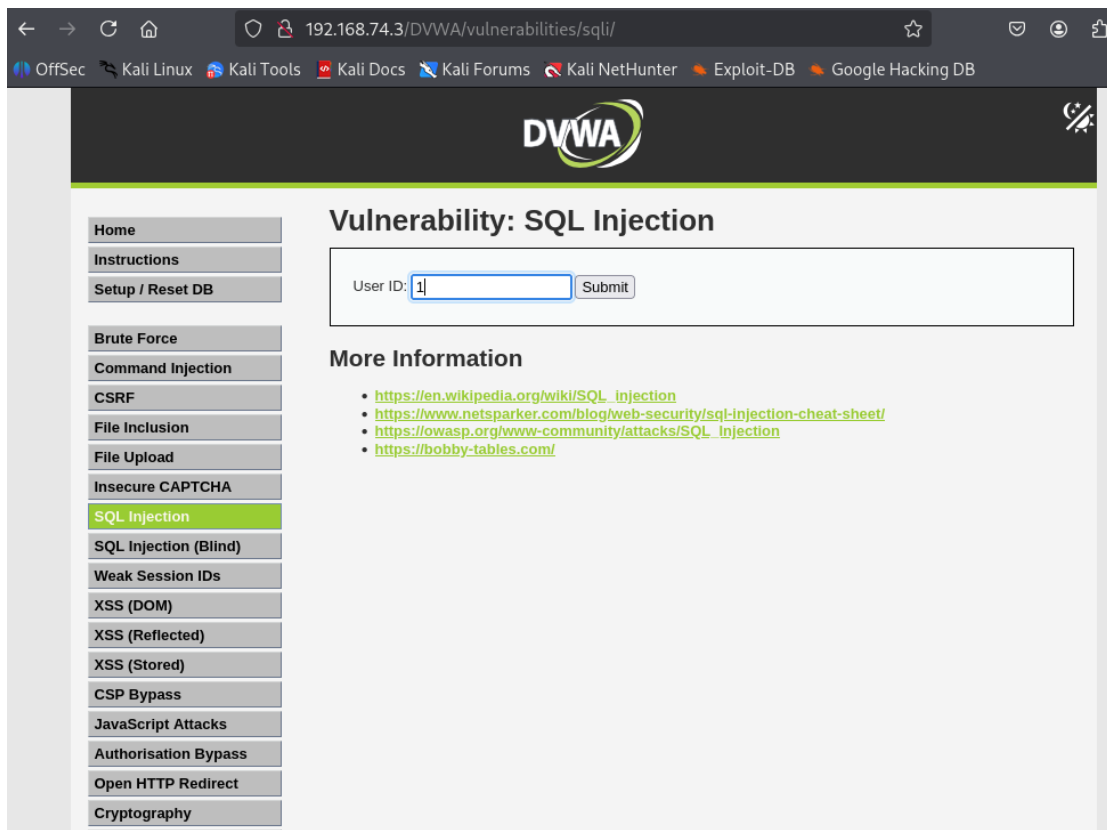


Figure 10. Evidence of insecure SQL-related application behavior during testing.

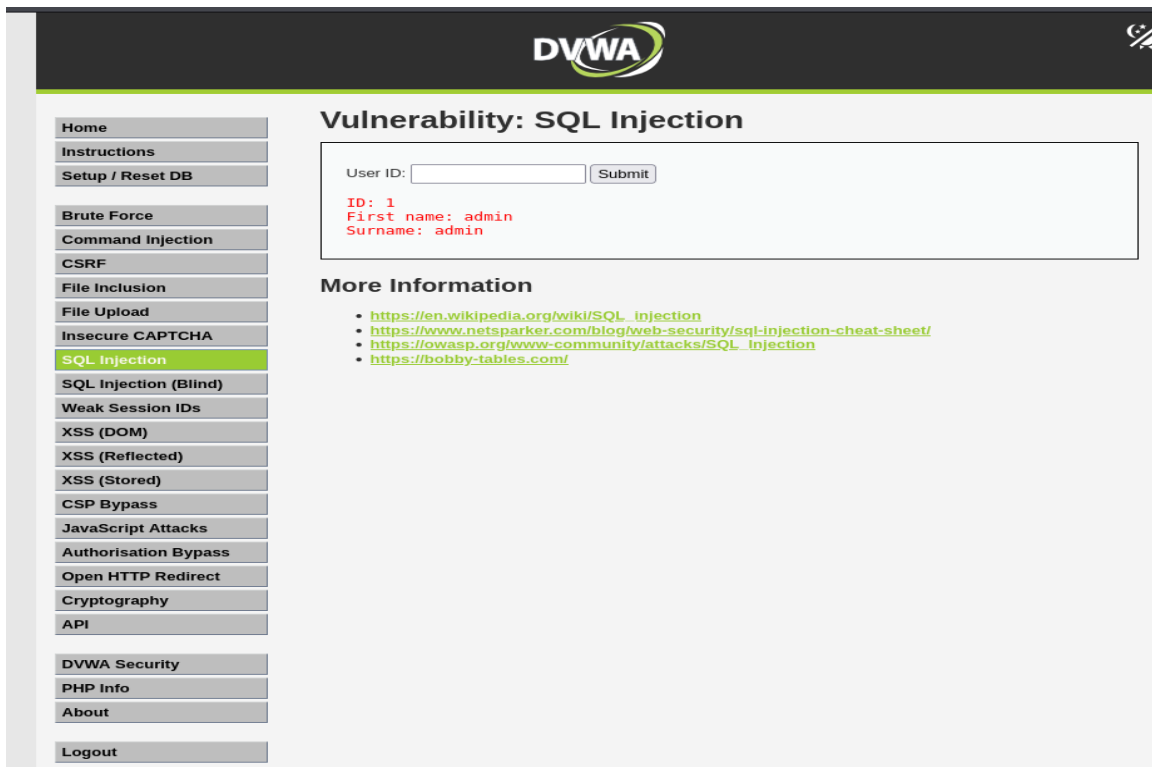


Figure 11. Reflected XSS test interface within DVWA.

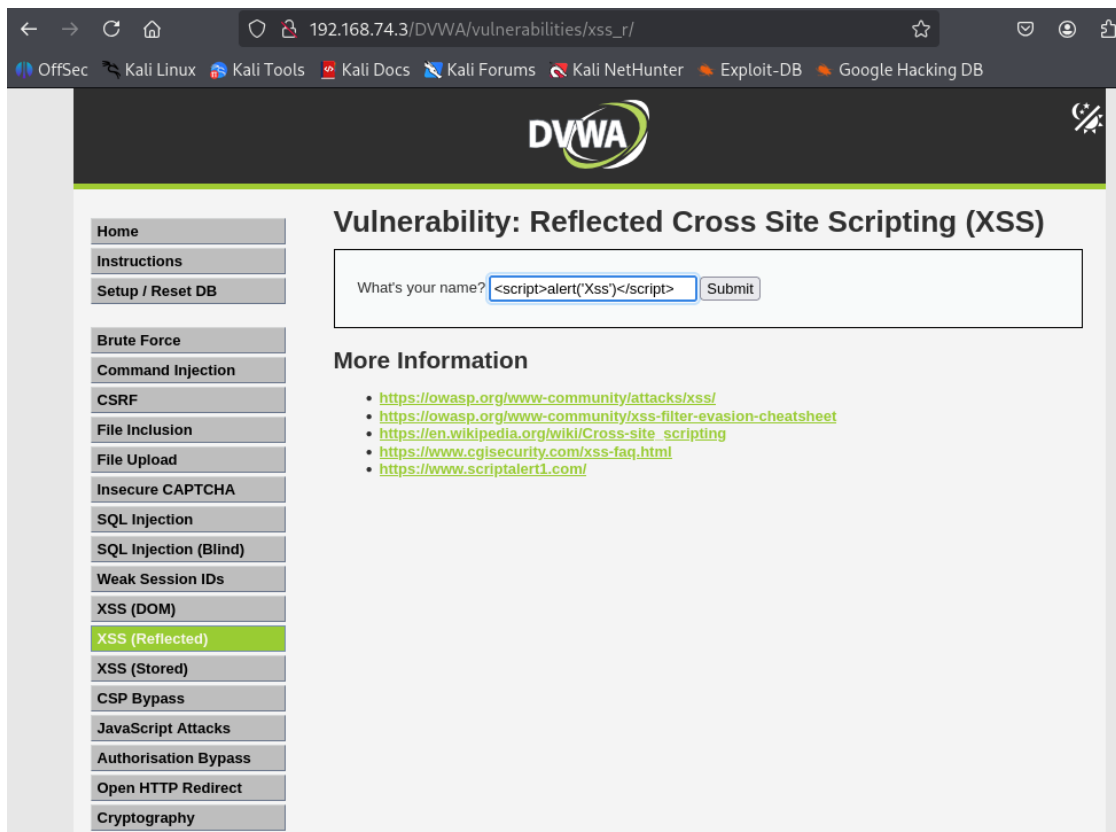
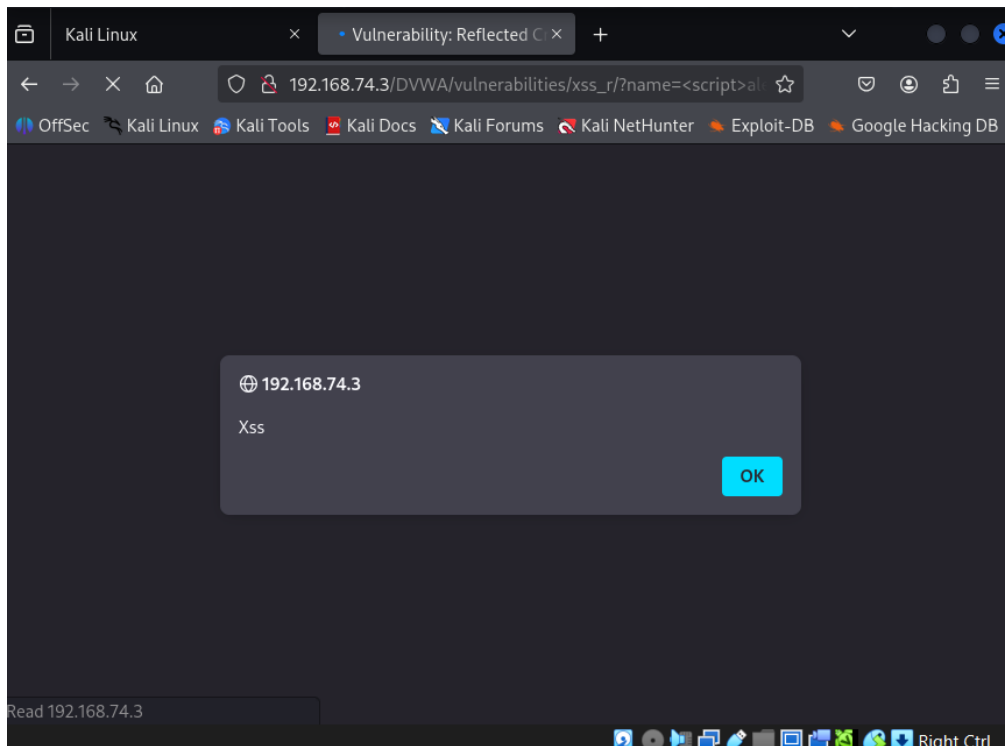


Figure 12. Evidence of reflected input behavior consistent with XSS exposure.



7. Blue Team – Defensive Analysis

The Blue Team analysis assessed the ability of the environment to prevent, detect, or respond to the actions conducted in the offensive evaluation. It appears that the environment did not provide effective defenses against the attacker's actions since he was capable of discovering the target, enumerating its services, accessing the web application, and probing its vulnerable modules without any apparent limitations. This implies that some preventive measures such as strict service exposure policies, network or application layer filtering, and others were either ineffective or consciously neglected in the simulation.

In terms of detection, the environment lacked sufficient signs of proactive monitoring or response to the actions of the attacker. Specifically, there were no indications of the application rejecting his requests or generating alerts when receiving the queries. The lack of such actions in practice means that the attacker could have conducted reconnaissance and probed the application with little risk of being noticed by defenders. This increases the chances of successfully compromising the target and prolongs the dwell time of the attacker.

Moreover, the Blue Team viewpoint reveals that additional steps should be taken to detect malicious activity in the environment. For instance, the application can log all incoming requests; however, logging alone may not be sufficient if the logs are not analyzed in the proper way. The attacker's login attempt, repeated requests, and the enumeration of vulnerable modules should trigger specific monitoring processes, notifications, or other responses. Moreover, exposed services like SSH should only allow connections from specific IP addresses.

Thus, the environment can be enhanced by introducing additional preventive measures such as strict service exposure policies, improved authentication, monitoring and alerting procedures, web application protection, and system hardening.

Figure 13. Web server access log evidence of requests made during the assessment.

```
File Actions Edit View Help
[sudo] password for hasitha:
192.168.74.5 - - [06/Apr/2026:07:25:46 -0400] "GET /DVWA/security.php HTTP/1.1" 302 678 "-" Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
192.168.74.5 - - [06/Apr/2026:07:25:46 -0400] "GET /DVWA/login.php HTTP/1.1" 200 1296 "-" Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
192.168.74.5 - - [06/Apr/2026:07:25:46 -0400] "GET /DVWA/dvwa/css/login.css HTTP/1.1" 200 741 "http://192.168.74.3/DVWA/login.php" Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
192.168.74.5 - - [06/Apr/2026:07:25:46 -0400] "GET /DVWA/dvwa/images/login_logo.png HTTP/1.1" 200 9374 "http://192.168.74.3/DVWA/login.php" Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
192.168.74.5 - - [06/Apr/2026:08:00:11 -0400] "GET /DVWA/vulnerabilities/sqli/ HTTP/1.1" 200 1789 "http://192.168.74.3/DVWA/security.php" Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
192.168.74.5 - - [06/Apr/2026:08:00:11 -0400] "GET /DVWA/dvwa/js/add_event_listeners.js HTTP/1.1" 200 619 "http://192.168.74.3/DVWA/vulnerabilities/sqli/" Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
192.168.74.5 - - [06/Apr/2026:08:00:11 -0400] "GET /DVWA/dvwa/js/dvwaPage.js HTTP/1.1" 200 901 "http://192.168.74.3/DVWA/vulnerabilities/sqli/" Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
192.168.74.5 - - [06/Apr/2026:08:00:11 -0400] "GET /DVWA/dvwa/css/main.css HTTP/1.1" 200 1681 "http://192.168.74.3/DVWA/vulnerabilities/sqli/" Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
192.168.74.5 - - [06/Apr/2026:08:00:11 -0400] "GET /DVWA/dvwa/images/logo.png HTTP/1.1" 304 249 "http://192.168.74.3/DVWA/vulnerabilities/sqli/" Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
192.168.74.5 - - [06/Apr/2026:08:00:11 -0400] "GET /DVWA/dvwa/images/theme-light-dark.png HTTP/1.1" 304 248 "http://192.168.74.3/DVWA/vulnerabilities/sqli/" Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
192.168.74.5 - - [06/Apr/2026:08:02:27 -0400] "GET /DVWA/vulnerabilities/sqli/?id=1%27+OR+%27%3D%27%27+--+&Submit=Submit HTTP/1.1" 200 1873 "http://192.168.74.3/DVWA/vulnerabilities/sqli/" Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
192.168.74.5 - - [06/Apr/2026:08:12:14 -0400] "GET /DVWA/vulnerabilities/sqli/?id=1%27+OR+%27%3D%27%27+--+&Submit=Submit HTTP/1.1" 200 1811 "http://192.168.74.3/DVWA/vulnerabilities/sqli/?id=1%27+OR+%27%3D%27%27+--+&Submit=Submit" Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
192.168.74.5 - - [06/Apr/2026:08:14:25 -0400] "GET /DVWA/vulnerabilities/xss_r/ HTTP/1.1" 200 1841 "http://192.168.74.3/DVWA/vulnerabilities/sqli/?id=1%27+OR+%27%3D%27%27+--+&Submit=Submit" Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
192.168.74.5 - - [06/Apr/2026:08:16:11 -0400] "GET /DVWA/vulnerabilities/xss_r/?name=hasitha HTTP/1.1" 200 1855 "http://192.168.74.3/DVWA/vulnerabilities/xss_r/" Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
192.168.74.5 - - [06/Apr/2026:08:17:05 -0400] "GET /DVWA/vulnerabilities/xss_r/?name=Test HTTP/1.1" 200 1853 "http://192.168.74.3/DVWA/vulnerabilities/xss_r/?name=hasitha" Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
192.168.74.5 - - [06/Apr/2026:08:17:25 -0400] "GET /DVWA/vulnerabilities/xss_r/?name=Hasitha HTTP/1.1" 200 1855 "http://192.168.74.3/DVWA/vulnerabilities/xss_r/?name=Test" Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
```

Figure 14. Service status evidence from the victim system.

```
(hasitha@hasitha)-[/var/www/html/DVWA]
$ sudo systemctl status apache2
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/usr/lib/systemd/system/apache2.service; disabled; preset: disabled)
   Active: active (running) since Mon 2026-04-06 04:06:36 EDT; 4h 32min ago
 Invocation: ce68c73b045d4e29823bd450d5ec4feb
    Docs: https://httpd.apache.org/docs/2.4/
   Process: 3857 ExecStart=/usr/sbin/apachectl start (code=exited, status=0/SUCCESS)
   Main PID: 3873 (apache2)
     Tasks: 9 (limit: 6666)
   Memory: 33.6M (peak: 34.1M)
     CPU: 1.373s
   CGroup: /system.slice/apache2.service
           └─3873 /usr/sbin/apache2 -k start
           └─3876 /usr/sbin/apache2 -k start
           └─3877 /usr/sbin/apache2 -k start
           └─3878 /usr/sbin/apache2 -k start
           └─3879 /usr/sbin/apache2 -k start
           └─3880 /usr/sbin/apache2 -k start
           └─4680 /usr/sbin/apache2 -k start
           └─4708 /usr/sbin/apache2 -k start
           └─4709 /usr/sbin/apache2 -k start

Apr 06 04:06:36 hasitha systemd[1]: Starting apache2.service - The Apache HTTP Server...
Apr 06 04:06:36 hasitha apachectl[3872]: AH00558: apache2: Could not reliably determine the server's fully qualified domain name, please see the /etc/httpd/conf/httpd.conf file for details.
Apr 06 04:06:36 hasitha systemd[1]: Started apache2.service - The Apache HTTP Server.
lines 1-24/24 (END)
```

8. Purple Team – Collaboration and Effectiveness

Purple team assessment determined how effective the attack methods would be in relation to the defensive posture of the environment. The Purple team found out that the Red team could conduct reconnaissance, service discovery, and application testing activities without facing much difficulty. However, when looking from a blue team perspective, the environment did not have any robust measures put in place to stop these attacks or detect them quickly.

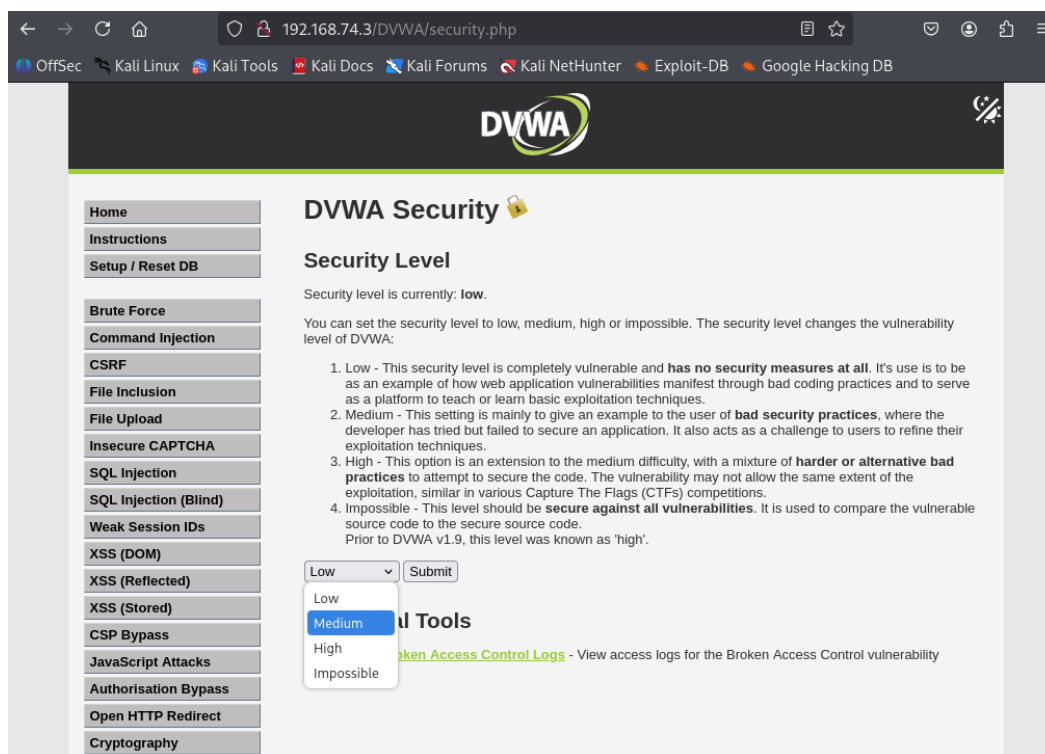
The main advantage of the Purple Team approach is the opportunity to turn the results of technical analysis into practical measures aimed at strengthening the organization's security position. In this situation, such measures as the reduction of superfluous services, the enhancement of the security level for the authentication procedure, the enforcement of safe programming techniques, and the improvement of application monitoring would significantly reduce the number of discovered vulnerabilities. Thus, enhanced SSH security would prevent the exploitation of the admin services, while correct queries would solve application problems.

The Purple Team also highlights the importance of continual coordination of the offensive and defensive measures. Instead of treating penetration testing and defense as two different actions, the company should utilize the results of the Red Team in improving the defenses of the Blue Team and then test the effectiveness of the improvements made.

From this standpoint, in the current case, the Purple Team suggests that the cooperation of vulnerability discovery and defense improvements will be highly beneficial. Further assessment of the system's strengths after making the suggested alterations would confirm this conclusion.

For confirmation that the recommended improvements are effective against the security threats, the system needs to be tested again following the implementation of stronger authentication techniques, access control on services, and input validation. After applying these solutions, attempts at abusing the logins, querying the system, and running scripts should be considerably more difficult or completely impossible.

Figure 15. Optional validation of a defensive or configuration adjustment.



9. Technical Findings

The following technical findings summarize the main weaknesses identified during the assessment.

Finding 1: Exposed SSH Service on Port 22

Severity: Low

Description: Service enumeration identified that the target host exposed SSH on port 22 to the attacker subnet.

Evidence: Refer to Figure 5.

Impact: An exposed administrative service increases the attack surface and may allow unauthorized access attempts if weak credentials or misconfiguration exist.

Recommendation: Restrict SSH access to trusted systems only, enforce strong authentication, and monitor connection attempts.

Finding 2: Exposed HTTP Service on Port 80

Severity: Low

Description: The target system exposed an HTTP service hosting the DVWA application.

Evidence: Refer to Figures 5 and 6.

Impact: Publicly reachable web services increase exposure to application-layer attacks and reconnaissance.

Recommendation: Harden the web server, review service exposure, and ensure only necessary services remain accessible.

Finding 3: Weak Authentication-Related Controls

Severity: Medium

Description: The application behavior indicated limited resistance to repeated login attempts.

Evidence: Refer to Figures 6, 7, and 8, 8.1, 8.2

Impact: Weak authentication protections may enable brute-force attacks or account compromise.

Recommendation: Implement account lockout, rate limiting, stronger password requirements, and additional authentication protections where appropriate.

Finding 4: SQL Injection Exposure

Severity: High

Description: Testing of application input handling indicated unsafe interaction with backend query logic.

Evidence: Refer to Figures 9 and 10.

Impact: SQL Injection may allow unauthorized data retrieval, query manipulation, and compromise of data confidentiality and integrity.

Recommendation: Use parameterized queries, server-side validation, and secure coding practices for all database interactions.

Finding 5: Reflected Cross-Site Scripting Exposure

Severity: Medium

Description: User input was reflected back in application output without sufficient output encoding or sanitization.

Evidence: Refer to Figures 11 and 12.

Impact: Reflected XSS may enable script execution in the browser, affect user trust, and expose sessions or sensitive interactions.

Recommendation: Apply output encoding, sanitize user input, and review the application for unsafe rendering behavior.

10. Business Impact Assessment

Despite conducting this analysis in a lab environment, these vulnerabilities highlight security threats that will pose a grave risk in production environments. Open ports and services pose the threat of being probed, scouted for reconnaissance, and targeted through unauthorized access attempts. Lack of authentication protection makes an application vulnerable to attacks, leading to compromised accounts and subsequently the exploitation of administrative and user functionality.

The SQL injection vulnerability is very critical because it might impact the application's confidentiality and integrity by exposing application data. Should this happen in a live business setting, then the confidentiality and integrity of sensitive data might be breached, altering the integrity of data, and eroding the confidence of the organization to keep their data safe. Likewise, the reflected cross-site scripting vulnerability might compromise the user experience and erode trust in the application and its security practices.

In general, an attack on any of the vulnerabilities highlighted in this report would lead to costly remediation processes, investigation expenses, service interruption, recovery costs, and loss of reputation and client trust. Despite there being no financial losses, there might still be serious costs from the operational and reputational perspectives. Therefore, it is crucial to develop applications using secure coding practices, minimizing exposure, and monitoring the application for vulnerabilities.

11. Remediation Roadmap

The remediation roadmap below prioritizes security improvements based on the findings of the assessment.

Immediate Actions (0–7 days)

- Restrict SSH access to trusted systems and approved IP addresses only.
- Review the exposed web service configuration and disable unnecessary services or features.
- Confirm that only required ports are open and reachable.

Short-Term Actions (1–2 weeks)

- Introduce account lockout and rate limiting controls to reduce repeated authentication abuse.
- Correct insecure input handling related to SQL Injection by implementing parameterized queries and server-side validation.
- Apply proper output encoding to prevent reflected script execution in application responses.

Medium-Term Actions (2–4 weeks)

- Improve logging and monitoring for suspicious authentication attempts and unusual web requests.
- Review firewall and access control policies for both administrative and application services.
- Apply service hardening and regular patch management to the server and web application stack.

Long-Term Actions (1–2 months)

- Establish secure coding practices throughout the development lifecycle.
- Conduct regular vulnerability assessments and penetration tests.
- Improve collaboration between security testing and defensive monitoring teams through repeated Purple Team validation exercises.

This remediation plan supports the assignment requirement to recommend improvements needed to mitigate and remediate threats arising from the discovered vulnerabilities.

12. Conclusion

This simulation clearly demonstrates that there are several avenues from which the environment of Mayo Industries can be attacked; for example, service exposure, authentication protection, application security, and defense preparedness. In this regard, the Red Team was able to find out the host of the environment, determine the services, and highlight a number of very important issues related to the applications. From the perspective of the Blue Team's analysis, the environment needs to have better control and monitoring systems to be prepared from a defensive perspective. This can easily be done using the comparison carried out by the Purple Team.

What the environment needs is reduced exposure, improved authentication, proper application coding, and improved monitoring.